Hardening Email Sender Authentication: A Lab-Based Evaluation of SPF/DKIM/DMARC Misconfigurations

Guilherme Ferreira João Oliveira Ayrton da Cruz Ana Lúcia Ferreira
Faculdade de Engenharia Universidade do Porto

Maio 28, 2026

Experimental Workflow

- 1- Infrastructure Setup → Docker/BIND/Postfix
- 2- Authentication Analysis → SPF/DKIM/DMARC
- 3- Spoofing Attacks → swaks + espoofer
- 4- SMTP Artefact Analysis → logs + headers
- 5- ML-Based Detection → classifiers
- 6- Infrastructure Hardening → DNS fixes
- 7- Experimental Results → evaluation

Why Email Spoofing Still Works

initializing threat analysis...

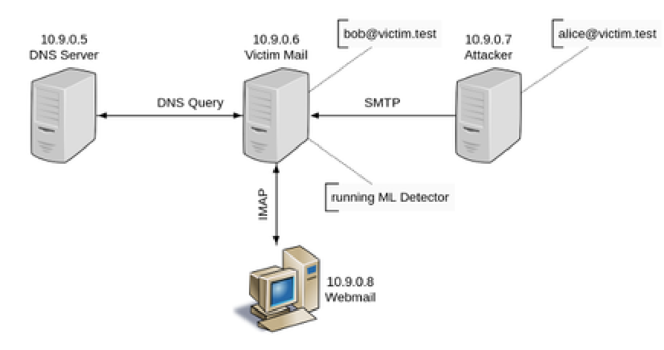
Problem	Reality	Consequence
Phishing remains highly effective	Authentication protocols are often misconfigured	Trusted identities can be impersonated

Authentication does not automatically mean security.

To understand why spoofing still succeeds, we first need to examine the lab infrastructure.

Lab Architecture

loading isolated email infrastructure...



Container	Role
DNS Server	SPF/DKIM/DMARC
Victim Mail Server	Postfix + Dovecot
Attacker Containe	swaks + espoofer
Webmail	Inbox inspection

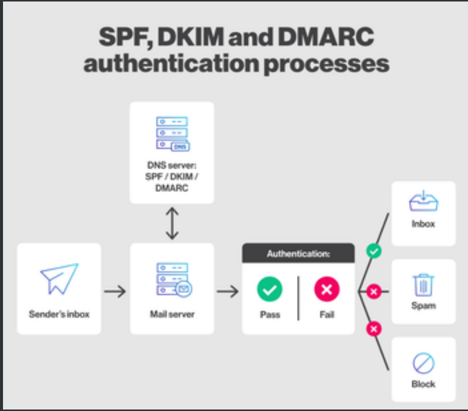
Docker-based isolated infrastructure (10.9.0.0/24)

Now that the infrastructure is established, we can examine how SPF, DKIM and DMARC behave inside the lab.

Authentication Overview

initializing protocol analysis...

Protocol	Validates
SPF	SMTP MAIL FROM
DKIM	Cryptographic Signature
DMARC	Domain Alignment.



Authentication does not automatically mean security.

To understand why spoofing still succeeds, we intentionally deployed weak authentication policies inside the DNS infrastructure.

Vulnerable Configuration

loading insecure DNS policies...

SPF

```
(attacker)$ dig TXT victim.test @10.9.0.5
"v=spf1 mx ~all"
```

DMARC

```
(attacker)$ dig TXT _dmarc.victim.test @10.9.0.5
"v=DMARC1; p=none; aspf=r; adkim=r"
```

DKIM Status

DKIM Selector:
NOT PUBLISHED

Weakness	Impact
SPF soft-fail (~all)	suspicious mail accepted
Missing DKIM	unverifiable signatures
DMARC p=none	monitoring only
Relaxed alignment	easier spoofing

Misconfiguration creates the attack surface.

With these weak policies in place, we can now demonstrate how SPF spoofing succeeds in practice.

SPF Spoofing Attack

executing direct MTA spoofing...

Attack Command

(attacker)$ ./attack.sh attacker@victim.test

Envelope Sender

MAIL FROM: attacker@attacker.test

Visible Sender

From: Alice <alice@victim.test>

Result

Spoofed email successfully delivered.

Authentication Observation

Protocol	Result
SPF	PASS
DKIM	NONE
DMARC	NONE/PASSIVE

SPF validates the envelope sender — not the visible sender.

Although SPF passes, the visible identity remains spoofed. This mismatch becomes even more dangerous when combined with protocol inconsistencies and advanced bypass techniques.

Advanced Authentication Bypass

loading multi-layer spoofing techniques...

Attack Command

(attacker)$ python3 espoofer.py -id server_a2

Attack Goal

Bypass SPF/DKIM/DMARC validation through protocol inconsistencies.

Exploited Weaknesses

- Parser inconsistencies
- Multiple From headers
- Relaxed alignment
- Protocol composition flaws

Result

Spoofed email delivered despite authentication mechanisms.

Authentication Observation

Mechanism	Status
SPF	PASS / PARTIAL
DKIM	BYPASSED
DMARC	RELAXED ALIGNMENT
User Perception	TRUSTED EMAIL

Secure protocols can still fail when incorrectly composed.

After reproducing advanced spoofing attacks, we analyzed SMTP artefacts and authentication traces to better understand attacker behaviour and support ML-based detection.

SMTP Artefact Analysis

analyzing authentication traces and mail headers...

HEADER ANALYSIS

TRAFFIC / ANALYSIS

SMTP artefacts reveal inconsistencies invisible to end users.

These authentication artefacts and SMTP inconsistencies were then transformed into features for ML-based spoofing detection.

ML-Based Spoofing Detection

Training classifiers for spoofed email detection...

FEATURE ENGINEERING

ML PIPELINE

ML acts as a final defensive layer when protocol-level authentication fails.

Feature	Legitimate	Spoofed
SPF	PASS	SOFTFAIL/P
DKIM	VALID	NONE
Return-	MATCH	MISMATCH

After analysing attack behaviour and developing detection mechanisms, we hardened the infrastructure to eliminate the vulnerabilities that enabled spoofing.

Infrastructure Hardening

deploying defence-in-depth protections...

BEFORE (VULNERABLE)

AFTER (HARDENED)

Improvement	Security Benefit
SPF hard-fail (-all)	rejects unauthorized senders
DKIM signing	cryptographic authenticity
DMARC reject policy	blocks spoofed mail
Strict alignment	prevents domain mismatch abuse

Defence-in-depth significantly reduces spoofing success.

Experimental Results & Conclusion

evaluating defence effectiveness...

RESULTS TABLE

Configuration	Attack Success
No Authentication	YES
SPF Soft-Fail (~all)	YES
DMARC p=none	YES
Relaxed Alignment	YES
Hardened Policies	BLOCKED

KEY LESSONS

- SPF alone is insufficient
- DMARC without enforcement is weak
- Protocol composition matters
- ML improves resilience
- Defence-in-depth is essential

"Email authentication protocols are only effective when correctly composed and strictly enforced."

Reproducible infrastructure enables realistic security experimentation.

> References

loading module...

> References I

Pro, tools > create image, accessed: 2026-04-06. [Online]. Available: https://gemini.google.com

O. Foundation, A02:2025 security miscon guration, https://owasp.org/Top10/2025/A02_2025-Security_Miscon guration/, 2025, accessed: 2026-03-16.

, A07:2025 authentication failures, https://owasp.org/Top10/2025/A07_2025-Authentication_Failures/, 2025, accessed: 2026-03-16.

J. Chen, V. Paxson, and J. Jiang, Composition kills: A case study of email sender authentication, Proceedings of the 29th USENIX Security Symposium, pp. 2183 2199, 2020.

J. Chen. (2024) Espoofer: An email spoo ng testing tool. Accessed: 2026-03-16. [Online]. Available: https://github.com/chenjj/espoofer

Infraforge. (2026) Spf, dkim, dmarc: Common setup mistakes. Accessed: 2026-03-16. [Online]. Available: https://www.infraforge.ai/blog/spf-dkim-dmarc-common-setup-mistakes

> References II

DMARCLY. (2024) How to implement dmarc/dkim/spf to stop email spoo ng/phishing. Accessed: 2026-03-16. [Online]. Available: https://dmarcly.com/blog/how- to- implement- dmarc- dkim- spf- to- stop- email- sp o o ng- phishing- the- de nitive- guide